信息安全测评与风险评估

7.3.2 物联网安全配置核查

授课教师：杨迎



目录

CONTENTS

01 案例导入——“被劫持的摄像头”

02 学习目标与标准定位

03 物联网安全配置核查六大维度

04 物联网安全测评实践与案例

Part.01

从案例引入到核心概念解析



案例导入——“被劫持的摄像头”（10分钟）



案例素材

2016年，Mirai利用物联网设备（主要是网络摄像头等）的**默认密码漏洞**，发动了美国史上**最大规模DDoS攻击**，导致Twitter等知名网站大面积瘫痪。

事后调查发现

- 大量设备使用**出厂默认密码**（如admin）
- 设备固件存在**已知漏洞但从未更新**
- 感知节点**暴露在公网**，无访问控制

案例讨论与结论

问题讨论

- 这些摄像头属于物联网的哪个层次？
- 如果按照等保2.0物联网扩展要求进行测评，应该检查哪些方面？
- 物联网安全测评与传统信息系统测评有什么不同？

结论

物联网感知层的安全测评，关注的是“设备本身的安全”——

- 物理防护
- 接入控制
- 身份鉴别
- 数据保护

Part.02

从案例引入到核心概念解析



学习目标

通过本课学习，你将能够：

01 理解

物联网安全扩展要求与安全通用要求的关系

02 掌握

物联网安全配置核查的核心测评指标（感知节点物理防护、接入控制、入侵防范、感知节点安全、网关节点安全、抗数据重放）

03

能够依据GB/T 22239物联网扩展要求进行安全配置核查

04

能够规范填写《物联网安全测评记录表》

物联网安全扩展要求——在等保中的位置

等保定位：GB/T 22239-2019 安全扩展要求 ➜ 物联网安全扩展要求物联网从架构上分为三层：感知层、网络传输层、处理应用层。

逻辑层	层次组成	安全要求来源
感知层	感知节点设备、网关节点设备、短距离通信	物联网安全扩展要求（重点）
网络传输层	互联网、移动通信网、多种网络融合	安全通用要求（通信网络、区域边界）
处理应用层	数据存储、智能处理、业务应用平台	安全通用要求（计算环境）

关键认识：物联网安全测评 = 安全通用要求 + 物联网安全扩展要求

Part.03

从案例引入到核心概念解析



物联网安全扩展要求的六个维度

第三级物联网安全扩展要求涵盖以下六个方面：

1 感知节点设备物理防护

核心关注点：物理破坏防护、环境适应性、电力供应**测评对象：**感知节点、网关节点

2 接入控制

核心关注点：只有授权的感知节点可以接入**测评对象：**感知节点、接入机制

3 入侵防范

核心关注点：限制通信目标地址，避免对陌生地址攻击**测评对象：**感知节点、网关节点

4 感知节点设备安全

核心关注点：授权配置、身份标识和鉴别**测评对象：**感知节点、网关节点

5 网关节点设备安全

核心关注点：合法设备标识鉴别、非法数据过滤、密钥在线更新**测评对象：**网关节点

6 抗数据重放

核心关注点：数据新鲜性鉴别、历史数据非法修改鉴别**测评对象：**感知数据、通信协议

维度一——感知节点设备物理防护

依据：GB/T 22239 8.4.1.1

测评指标及核查要点

指标类型	核查要点要求	测评方法
物理破坏防护	感知节点所处物理环境不应对设备造成物理破坏（挤压、强振动等）	现场检查部署环境，查阅验收文档
环境状态反映	感知节点在工作状态所处物理环境应能正确反映环境状态（如温湿度传感器不能安装在直射区）	现场核查安装位置是否合理
正常工作环境	感知节点所处物理环境不应影响其正常工作（强干扰、阻挡屏蔽等）	核查是否有防干扰、防屏蔽措施
电力供应	关键感知节点设备应具有可供长时间工作的电力供应；关键网关节点应具有持久稳定电力供应	检查供电方式、UPS配置、电力维护记录

常见避坑提示

- **传感器安装在阳光直射区域**
  → 温度读数偏差
- **室外设备无防护箱体**
  → 日晒雨淋导致设备故障
- **关键监控节点无UPS供电**
  → 断电后监控失效

维度二——接入控制

依据 / 测评指标

GB/T 22239 8.4.2.1：授权接入

核心核查要点

保证只有授权的感知节点可接入

核心测评方法

核查设备身份鉴别机制（如编码、证书、MAC白名单等）

具体核查要点

- 感知节点具有唯一身份标识（如设备ID/MAC绑定）
- 接入时进行身份校验（如密钥、数字证书）
- 建立合法设备白名单

测试方法

尝试用非授权设备接入传感网，验证是否被拒绝。

维度三——入侵防范

依据：GB/T 22239 8.4.2.2

测评指标

a 限制感知节点

应能够限制与感知节点通信的目标地址，避免对陌生地址的攻击；需登录感知节点查看配置并测试。

b 限制网关节点

应能够限制与网关节点通信的目标地址，避免对陌生地址的攻击；需登录网关节点查看配置并测试。

核查要点

- 感知节点是否配置了允许通信的白名单
- 网关节点是否配置了通信目标地址控制措施
- 是否能防止感知节点攻击外部陌生地址

测试方法

尝试让感知节点向非授权地址发送数据，验证是否被拦截。

维度四——感知节点设备安全

依据：GB/T 22239 8.4.3.1

测评指标与核查要点：

a **授权配置：**保证授权用户方可配置或变更软件应用；核查访问控制机制。

b **网关节点身份鉴别：**具备鉴别连接网关节点设备能力；核查是否支持至少一种机制。

c **其他感知节点鉴别：**具备鉴别连接其他感知节点设备能力；核查节点间认证机制。

具体核查要点：

- 防止非授权用户配置变更的技术手段
- 感知节点与网关节点间的双向身份鉴别
- 支持MAC绑定、通信协议限定等鉴别方式

维度五——网关节点设备安全

依据：GB/T 22239 8.4.3.2

测评指标与核查要点：

a 合法设备标识鉴别

应具备对连接设备标识鉴别能力；核查鉴别机制。

b 非法数据过滤

应具备过滤非法和伪造节点数据能力；核查过滤机制。

c 关键密钥在线更新

授权用户能在线更新关键密钥；核查更新功能。

d 关键配置参数在线更新

授权用户能在线更新关键配置；核查更新功能。

常见问题

- 网关节点无数据过滤机制，接受所有来源数据
- 密钥长期不变，无更新机制
- 无配置参数更新能力，固件版本老旧

维度六——抗数据重放

依据：GB/T 22239 8.4.3.3

测评指标与核查要点：

数据新鲜性鉴别	应能够鉴别数据的新鲜性，避免历史数据的重放攻击； • 核查数据包是否包含时间戳或序列号，尝试重放攻击测试。
历史数据非法修改鉴别	应能够鉴别历史数据的非法修改，避免数据的修改重放攻击； • 核查数据完整性校验机制。

Part.04

从案例引入到核心概念解析



物联网安全测评——实践五步法


素材4：物联网安全测评快速参考卡.(


素材5：物联网测评工具清单.docx

步骤 1
收集资料
收集感知节点清单、网关节点配置、部署环境文档

工具/方法
文档审阅

步骤 2
现场检查
检查物理部署环境：安装位置、供电方式、防护措施

工具/方法
现场勘察

步骤 3
登录核查
登录感知/网关节点，查看：通信目标地址、访问控制、身份鉴别

工具/方法
设备管理终端

步骤 4
功能测试
测试接入控制、身份鉴别、抗重放功能是否有效

工具/方法
模拟/渗透测试

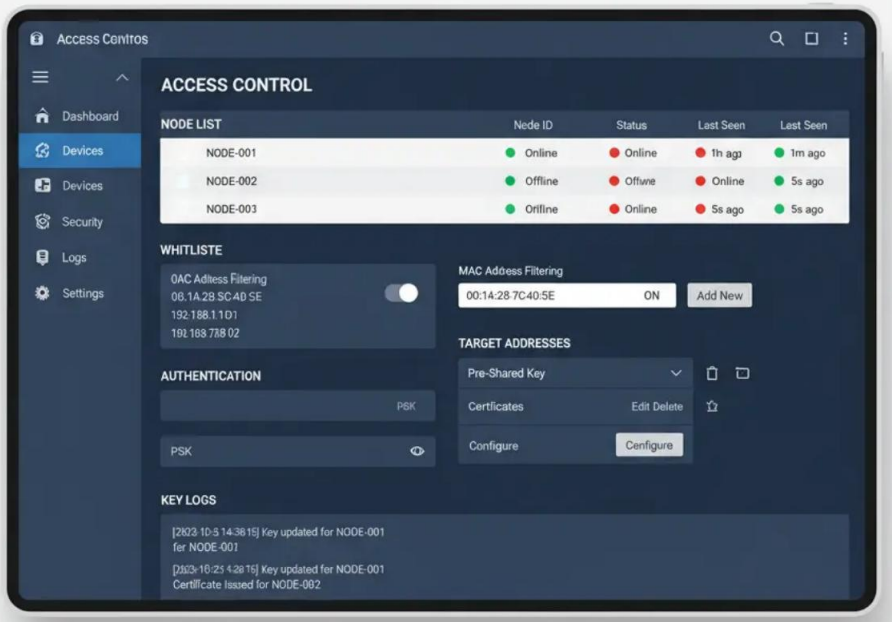
步骤 5
记录填写
填写《物联网安全测评记录表》

工具/方法
测评记录表

教师演示——物联网测评模拟平台操作

演示场景

- 节点列表：显示已注册节点及状态
- 接入控制：设备白名单、MAC绑定
- 目标地址：感知节点允许通信的IP
- 身份鉴别：预共享密钥/证书配置
- 密钥记录：关键密钥更新日志



教师演示步骤

登录平台 → 查节点清单 → 查/设白名单 → 非授权接入测试 → 目标地址限制

重点强调：配置如何对应等保扩展要求

实践任务1——物联网安全配置核查（35分钟）

素材1：实践任务
——模拟物联网系统

任务名称 **模拟物联网系统安全配置核查**

任务场景 教师提供模拟物联网系统环境（含感知节点、网关节点、管理平台）及配置文件

分组安排 4人/组（测评工程师、记录员、验证测试员、报告编写员）

时间安排 **约35分钟**

核心任务步骤

01 检查感知节点物理部署环境（使用照片/3D模型）

02 核查接入控制配置白名单、身份鉴别

实践任务1——《物联网安全测评记录表》填写说明

素材2：实践任务
——《物联网安全测

维度	指标项	测评记录	备注
感知节点物理防护	a)物理环境不对设备造成破坏		
	b)环境能正确反映状态		
	c)环境不影响正常工作		
	d)关键节点电力供应		
接入控制	只有授权的感知节点可接入		
入侵防范	限制感知节点通信目标地址		
	限制网关节点通信目标地址		
感知节点安全	a)授权用户配置变更		
	b)网关节点身份鉴别		
	c)其他感知节点身份鉴别		
网关节点安全	a)合法设备标识鉴别		
	b)非法数据过滤		
	c)关键密钥在线更新		
	d)关键配置在线更新		
抗数据重放	a)数据新鲜性鉴别		
	b)历史数据非法修改鉴别		

实践任务2——案例分析（15分钟）

素材3：案例分析
——智能家居物联网

案例场景

某智能园区部署了物联网系统，包含：温湿度传感器200个（感知节点）、智能照明控制器50个（感知节点+执行器）、物联网网关4台、云平台1套

已知问题

① 部分传感器室外无防护箱体
② 网关未启用接入控制白名单
③ 感知节点使用出厂默认口令
④ 无数据新鲜性保护机制
⑤ 密钥从未更新过

任务内容

① 分析这些问题对应等保测评指标
② 判断问题合规性（符合/部分/不符合）
③ 提出整改建议

产出： 完成案例分析的《物联网安全测评记录表》

Part.05

从案例引入到核心概念解析



物联网安全测评中的常见误区

误区 ✗	正确理解 ☑
“物联网设备小，不用做等保”	物联网系统同样需要等保测评，需同时满足安全通用要求和扩展要求
“只要能联网就行，安全不关我事”	感知节点被控制可能成为攻击跳板（如Mirai僵尸网络）
“出厂默认密码很安全”	默认密码是物联网设备最常见的安全风险，必须强制修改
“物理环境安全不重要”	感知节点部署在无人值守环境，物理安全是第一步防线
“数据重放攻击只有理论可能”	历史数据重放可造成虚假信息注入、控制指令重发等实际危害

思政融入——物联网安全关乎人身安全

安全

- 智能医疗设备（心脏起搏器、胰岛素泵）被攻击 → 危及生命
- 智能网联汽车被远程控制 → 交通事故
- 智能家居被入侵 → 隐私泄露、家庭安全

责任

- 测评工程师不仅要检查技术配置，更要意识到其背后的社会影响
- 一个默认密码，可能成为僵尸网络的“敲门砖”

合规

- 等保2.0物联网扩展要求是国家对物联网安全的强制规范
- 合规测评是保障物联网健康发展的制度保障

一句话： 物联网安全测评，守护的不仅是数据，更是人身安全和社会稳定。

Part.06

从案例引入到核心概念解析



知识点回顾（5分钟）

物联网安全配置核查

核心结构

一、等保中的位置

安全通用要求 + 物联网安全扩展要求

（感知节点 + 网关节点）

二、六个测评维度

1. 感知节点物理防护（防破坏/环境/电力）
2. 接入控制（授权节点接入）
3. 入侵防范（限制目标地址）
4. 感知节点设备安全（授权配置/身份标识）
5. 网关节点设备安全（鉴别/过滤/更新）
6. 抗数据重放（新鲜性/完整性）

三、实践五步法

收集资料 → **现场检查** → **登录核查** → **功能测试** → **填写记录表**

课后作业与下节课预告

课后作业

- **必做：**完成《物联网安全测评记录表》填写，提交至学习通
- **必做：**完成活动7.3.2在线测试（共15题）
- **选做：**调研常见物联网设备（如智能摄像头），分析安全风
- **预习：**预习7.4.1“工控系统架构认知”

下节课预告：7.4.1 工控系统架构认知

- **预告内容：**工业控制系统五层架构、实时性要求、安全扩展要求概述
- **课前准备：**复习GB/T 22239扩展要求，了解常见设备（PLC、DCS等）

课堂小结与答疑

三个核心知识点

① 物联网安全测评 = 安全通用要求 + 物联网安全扩展要求

② 六个测评维度（物理防护、接入控制、入侵防范、感知节点安全、网关节点安全、抗数据重放）

③ 感知节点和网关节点是测评的核心对象

两个关键技能

① 能依据GB/T 22239物联网扩展要求进行安全配置核查

② 能规范填写《物联网安全测评记录表》

一个职业准则：

物联网安全关乎人身安全，测评工作责任重大

感谢观看

